

Incident Report — MySQL Data Ransom / Exposed Windows Host Compromise

1. Executive Summary

An internet-facing Windows host (`corp-ae1-872d`) was running a MySQL instance that allowed remote `root` login with no effective authentication. Starting **Aug 16, 2026 03:07:47 UTC**, an external actor (IP `64.89.163.139`) enumerated and dropped three databases (`sakila`, `cr_corp_01`, `world`) and left a self-service ransom note in a newly created `RECOVER_YOUR_DATA` table demanding 0.0134 BTC. The same MySQL service continued to receive successful `root` logins from over a dozen additional external IPs through Aug 18, indicating the exposure was found and re-exploited by multiple opportunistic scanners after the initial attack. Separately, the same host's RDP/Windows logon surface was hit by a credential brute-force campaign against the `administrator` account from four external IPs; the `administrator` account subsequently logged on successfully (including one interactive RDP session) from three other external IPs. No endpoint evidence (process, file, registry) of malware, ransomware binary execution, or data staging/exfiltration was found — this was a **database-layer "empty-shell" ransom** (drop + note) rather than file encryption.

2. Incident Details

Field	Value
Detection date/time	Aug 16, 2026 03:07:47 UTC — earliest attacker activity recorded; Sentinel analytics rules for VM and MySQL logons were armed before exposure
Reporter	Rahul Patnala
Classification	Database extortion ("MySQL ransom" / data-destruction extortion), compounded by exposed RDP with brute-forced administrator account
Severity	High — production database(s) destroyed, admin-level account compromised on internet-facing host
Affected assets	<code>corp-ae1-872d</code> (single Windows host running MySQL); MySQL databases <code>cr_corp_01</code> , <code>sakila</code> , <code>world</code> , and the attacker-created <code>recover_your_data</code>
Observation window in data	Aug 15, 2026 16:14 UTC – Aug 19, 2026 00:38 UTC

3. Impact Assessment

- **Availability:** `cr_corp_01`, `sakila`, and `world` databases were dropped at **03:08:20–03:08:21 UTC on Aug 16**. `cr_corp_01` follows corporate-database naming and is the highest-value loss; it is first in line for restoration from backup.
- **Confidentiality:** Attacker ran `SELECT SUM(data_length+index_length) ... information_schema.tables` against each database before dropping it (sizing, consistent with reconnaissance). No successful bulk `SELECT *` of business tables and no outbound transfer to attacker infrastructure appeared in `DeviceNetworkEvents`. **This indicates no data exfiltration occurred.**
- **Integrity:** Databases were destroyed (`DROP DATABASE`), not modified/encrypted in place.
- **Scope:** Single host and single MySQL instance; no lateral movement seen in registry, file or process artifacts.
- **Business impact:** Loss of three databases (`cr_corp_01`, `sakila`, `world`) and a 0.0134 BTC ransom demand, contained to a single host that was isolated after the breach.

4. Indicators of Compromise

Type	Value	Source
BTC address (found in logs)	<code>bc1q7jps5432akuf1g9flw2vu6hgmmj5hr rdu6c5gm</code>	<code>mysql_query_logs.csv</code>
Contact email (found in logs)	<code>ak+2alf4@onionmail.org</code>	<code>mysql_query_logs.csv</code>
Reference URL (found in logs)	<code>hxxps://bit[.]ly/22mysql</code>	<code>mysql_query_logs.csv</code>
DATAID (found in logs)	<code>2ALF4</code>	<code>mysql_query_logs.csv</code>
Primary DB attacker IP	<code>64.89.163.139</code> (first success, initiated DROPs)	<code>mysql_auth_logs.csv</code>
Other IPs w/ successful <code>root</code> DB login	<code>77.90.185.30, 77.90.185.21, 64.89.163.158, 64.89.163.78, 64.89.163.141, 64.89.163.176, 64.89.163.90, 64.89.163.80, 202.189.4.123, 213.209.159.115, 34.62.252.23</code>	<code>mysql_auth_logs.csv</code>

RDP brute-force source IPs (failed)	216.225.206.228, 160.250.224.93, 177.52.136.220, 203.124.40.82	vm_login_logs.csv
Successful administrator logon IPs	77.74.202.179, 94.26.68.54, 180.94.20.203	vm_login_logs.csv
Malicious/attacker artifact object	Database/table RECOVER_YOUR_DATA	mysql_query_logs.csv

Note: All indicators above were extracted directly from the MySQL query, MySQL authentication and device logon logs.

5. Timeline (all times as logged, source table cited)

Time (UTC as logged)	Event	Source
Aug 15, 2026 16:14–16:18	Baseline host telemetry begins (Defender sensor activity, no anomalies)	device_file_logs.csv
Aug 16, 2026 03:07:47–03:07:49	SHOW DATABASES and size-recon queries (information_schema.tables) run as root	mysql_query_logs.csv
Aug 16, 2026 03:07:51	First successful root login to MySQL, no/blank password indicated by preceding failure pattern, from 64.89.163.139	mysql_auth_logs.csv
Aug 16, 2026 03:07:48–03:08:22	RECOVER_YOUR_DATA database/table created; ransom note text inserted (BTC address, onionmail contact, DATAID 2ALF4)	mysql_query_logs.csv
Aug 16, 2026 03:08:20–03:08:21	DROP DATABASE executed against sakila, cr_corp_01, recover_your_data, world	mysql_query_logs.csv
Aug 16, 2026 03:08:22	Ransom note re-created after self-drop (attacker recreates note DB post-wipe)	mysql_query_logs.csv

Aug 16, 2026 04:25 – Aug 18, 2026 23:54	Repeated CREATE DATABASE RECOVER_YOUR_DATA / recon from additional external IPs (mass re-exploitation of the same open/unauthenticated MySQL exposure)	mysql_query_logs.csv, mysql_auth_logs.csv
Aug 16, 2026 18:46 onward	RDP brute-force against administrator account begins from 4 external IPs (216.225.206.228, 160.250.224.93, 177.52.136.220, 203.124.40.82)	vm_login_logs.csv
Aug 18, 2026 04:22 / 10:10	Successful administrator network logons from 94.26.68.54, 180.94.20.203	vm_login_logs.csv
Aug 18, 2026 20:09–20:10	Successful administrator network logon and interactive (RDP) logon from 77.74.202.179	vm_login_logs.csv
Aug 18, 2026 20:10–23:37	Interactive session activity: Edge browsing, OneDrive/Office telemetry, standard Windows Run-key entries (Edge auto-launch, OneDrive) — no malicious persistence or tooling observed	device_registry_logs.csv, device_network_logs.csv, device_file_logs.csv
Aug 19, 2026 00:35–00:38	Last recorded host activity (Defender data-collection artifacts)	device_file_logs.csv

6. Root Cause / Attack Vector

- **Primary vector (confirmed):** MySQL service on **corp-ae1-872d** was reachable from the internet and accepted **root** logins with effectively no working authentication barrier (135+ failed attempts from IP 77.90.185.30 alone against **sa/admin/root**, followed by successful **root** logins from many unrelated IPs) — caused by the weak **root** credentials and remote access configured on the honeypot. This is the entry point used for the database-drop/ransom.
- **Secondary vector (observed):** The Windows host's RDP/remote logon surface was independently targeted by password-guessing against the **administrator** account. Successful **administrator** logons came from three IPs that **do not overlap** with the four brute-force source IPs, **pointing to separate operators** finding and using the weak administrator password on the exposed RDP service.
- Process telemetry (**DeviceProcessEvents**) for the compromise window shows only routine **system** activity (Defender, Windows servicing, Edge update). **No**

attacker tooling or suspicious command lines were observed in the Aug 18 interactive session or from the MySQL service account.

- No file-encryption, ransomware binary, or persistence mechanism was found in `DeviceFileEvents/DeviceRegistryEvents` — consistent with a DB-only extortion technique rather than host-level ransomware.

7. Response Actions

Taken: Once the breach was confirmed, the device was isolated, cutting off attacker access and preventing further activity on the host.

Recommended hardening and recovery

- Contain: Remove public internet exposure of MySQL (bind to internal interface / restrict via NSG-firewall to known IPs; disable `root` remote login).
- Contain: Reset `administrator` and all local/DB credentials on `corp-ae1-872d`; enforce MFA or IP-restricted access for RDP; consider disabling direct internet-facing RDP in favor of a bastion/VPN.
- Eradicate: Audit all grants and remove any attacker-created MySQL accounts or privileges (`GRANT CREATE, DROP ON *.* TO root@%` was observed being (re)issued — audit all grants).
- Recover: Restore `cr_corp_01`, `sakila`, `world` from last known-good backup; verify backup integrity and take an offline copy going forward.
- Investigate: Review `cr_corp_01` and the other dropped databases against breach-notification requirements.

8. Evidence / KQL Hunts by Section

Section 2/5 – Timeline & initial access

```
// RDP/logon brute force and successful admin logons
DeviceLogonEvents
| where DeviceName == "corp-ae1-872d"
| where Timestamp between (datetime(2026-08-15T00:00:00Z) ..
datetime(2026-08-19T06:00:00Z))
| where AccountName in ("administrator","guest")
| summarize Attempts=count(), Successes=countif(ActionType=="LogonSuccess") by
RemoteIP, ActionType, bin(Timestamp, 1h)
| order by Timestamp asc
```

Microsoft Defender

Advanced hunting

Selected workspace: LAW-Cyber-Range

Help resources Query resources report Schema reference Page preferences

New query* x New query* x New query* x +

Query Run query

```

1 // RDP/Logon brute force and successful admin logons
2 DeviceLogonEvents
3 | where DeviceName == "corp-s81-972d"
4 | where Timestamp between (datetime(2026-08-15T00:00:00Z) .. datetime(2026-08-19T06:00:00Z))
5 | where AccountName in ("administrator","guest")
6 | summarize Attempts=count(), Successes=countif(ActionType=="LogonSuccess") by RemoteIP, ActionType, bin(Timestamp, 1h)
7 | order by Timestamp asc
8

```

Results Query history Getting started

Export Show empty columns 29 items Search 00:01:284 Low

RemoteIP	ActionType	Timestamp	Attempts	Successes
216.225.206.228	LogonFailed	Aug 17, 2026 7:30:00 PM	21	0
109.235.185.132	LogonFailed	Aug 17, 2026 8:30:00 PM	1	0
103.212.182.194	LogonFailed	Aug 17, 2026 8:30:00 PM	1	0
	LogonSuccess	Aug 18, 2026 3:30:00 AM	1	1
94.26.68.54	LogonSuccess	Aug 18, 2026 3:30:00 AM	1	1
	LogonSuccess	Aug 18, 2026 9:30:00 AM	1	1
180.94.20.203	LogonSuccess	Aug 18, 2026 9:30:00 AM	1	1

Section 4/5 – MySQL compromise and ransom note

MySQLAudit_CL

| where TimeGenerated between (datetime(2026-08-15T00:00:00Z) .. datetime(2026-08-19T06:00:00Z))

| where RawData has "Connect"

| extend IsFailure = RawData has "Access denied"

| extend IpAddress = extract(@"@'?(?[\d\.]+)'"', 1, RawData)

| extend Username = coalesce(

extract(@"user '([^\']+)'"', 1, RawData), // failure format: user 'sa'@'ip'

extract(@"Connect\s+(w+)"', 1, RawData)) // success format: root@ip

| summarize Failures = countif(IsFailure), Successes = countif(not(IsFailure)) by IpAddress, Username

| order by Successes desc

Microsoft Defender

Advanced hunting

Selected workspace: LAW-Cyber-Range

Help resources Query resources report Schema reference Page preferences

New query* x New query* x New query* x +

Query Run query

```

1 MySQLAudit_CL
2 | where TimeGenerated between (datetime(2026-08-15T00:00:00Z) .. datetime(2026-08-19T06:00:00Z))
3 | where RawData has "Connect"
4 | extend IsFailure = RawData has "Access denied"
5 | extend IpAddress = extract(@"@'?(?[\d\.]+)'"', 1, RawData)
6 | extend Username = coalesce(
7 |   extract(@"user '([^\']+)'"', 1, RawData), // failure format: user 'sa'@'ip'
8 |   extract(@"Connect\s+(w+)"', 1, RawData)) // success format: root@ip
9 | summarize Failures = countif(IsFailure), Successes = countif(not(IsFailure)) by IpAddress, Username
10 | order by Successes desc

```

Results Query history Getting started

Export Show empty columns 91 items Search 00:02:196 Low

Filters: Add filter

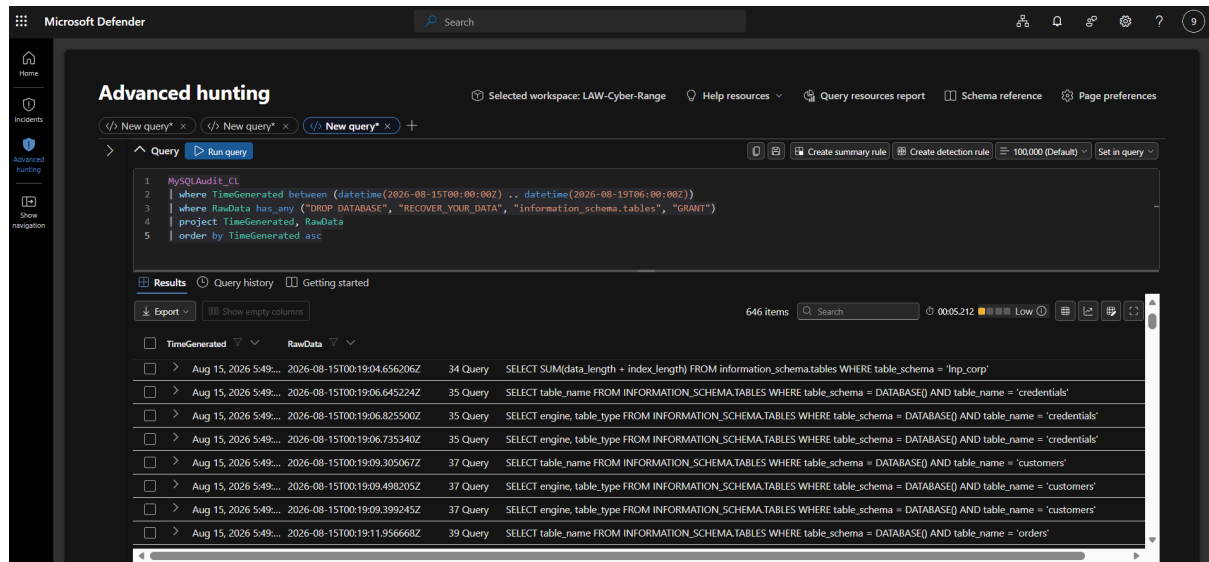
IpAddress	Username	Failures	Successes
77.90.185.30	root	224	448
	root	191	271
77.90.185.30	sa	224	224
77.90.185.30	admin	224	224
		0	200
184.46.132.128	root	46	188

MySQLAudit_CL

```

| where TimeGenerated between (datetime(2026-08-15T00:00:00Z) ..
datetime(2026-08-19T06:00:00Z))
| where RawData has_any ("DROP DATABASE", "RECOVER_YOUR_DATA",
"information_schema.tables", "GRANT")
| project TimeGenerated, RawData
| order by TimeGenerated asc

```



Section 6 – Root cause / lateral movement check

```

// Process execution on host during compromise window
DeviceProcessEvents
| where DeviceName == "corp-ae1-872d"
| where Timestamp between (datetime(2026-08-16T02:30:00Z) ..
datetime(2026-08-19T01:00:00Z))
| project Timestamp, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
| order by Timestamp asc

```

Advanced hunting

Selected workspace: LAW-Cyber-Range | Help resources | Query resources report | Schema reference | Page preferences

Query: `// Process execution on host during compromise window (once real DeviceProcessEvents is available)
2 DeviceProcessEvents
3 | where DeviceName == "corp-ae1-872d"
4 | where Timestamp between (datetime(2026-08-16T02:30:00Z) .. datetime(2026-08-19T01:00:00Z))
5 | project Timestamp, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName
6 | order by Timestamp asc`

Results: 4380 items

Timestamp	AccountName	FileName	ProcessCommandLine	InitiatingProcessFileName
Aug 16, 2026 8:29:...	system	SenseR.exe	"SenseR.exe" "OfflineSe..." msense.exe	
Aug 16, 2026 8:29:...	system	powershell.exe	powershell.exe -Executi... senseir.exe	
Aug 16, 2026 8:29:...	system	csc.exe	"csc.exe" /noconfig /full... powershell.exe	
Aug 16, 2026 8:29:...	system	cvrtres.exe	cvrtres.exe /NOLOGO /R... csc.exe	
Aug 16, 2026 8:30:...	system	rundll32.exe	"rundll32.exe" C:\Windo... svchost.exe	
Aug 16, 2026 8:32:...	system	MicrosoftEdgeUpdate.exe	"MicrosoftEdgeUpdate.e... svchost.exe	

Section 3 – Data exfiltration check

```
// Outbound connections from host during and after compromise window
DeviceNetworkEvents
| where DeviceName == "corp-ae1-872d"
| where ActionType == "ConnectionSuccess"
| where Timestamp between (datetime(2026-08-16T02:30:00Z) ..
datetime(2026-08-19T01:00:00Z))
| where RemoteIPType == "Public"
| summarize BytesEvidenceNotAvailable=count() by RemoteIP, RemoteUrl,
InitiatingProcessFileName
| order by RemoteIP asc
```

Advanced hunting

Selected workspace: LAW-Cyber-Range | Help resources | Query resources report | Schema reference | Page preferences

Query: `// Outbound connections from host during and after compromise window
2 DeviceNetworkEvents
3 | where DeviceName == "corp-ae1-872d"
4 | where ActionType == "ConnectionSuccess"
5 | where Timestamp between (datetime(2026-08-16T02:30:00Z) .. datetime(2026-08-19T01:00:00Z))
6 | where RemoteIPType == "Public"
7 | summarize BytesEvidenceNotAvailable=count() by RemoteIP, RemoteUrl, InitiatingProcessFileName
8 | order by RemoteIP asc
9`

Results: 822 items

RemoteIP	RemoteUrl	InitiatingProcessFileName	BytesEvidenceNotAvailable
104.120.129.21	windows.msn.com	widgets.exe	1
104.18.33.89		msedgeview2.exe	1
104.18.33.89		msedge.exe	1
104.208.16.94	v10.events.data.micr...	svchost.exe	2
104.208.16.94		mpdefendercoreservice...	1
104.208.16.94		onedrive.exe	1

Section 6 – Persistence check

```
// Registry Run-key / persistence changes around compromise window
```

DeviceRegistryEvents

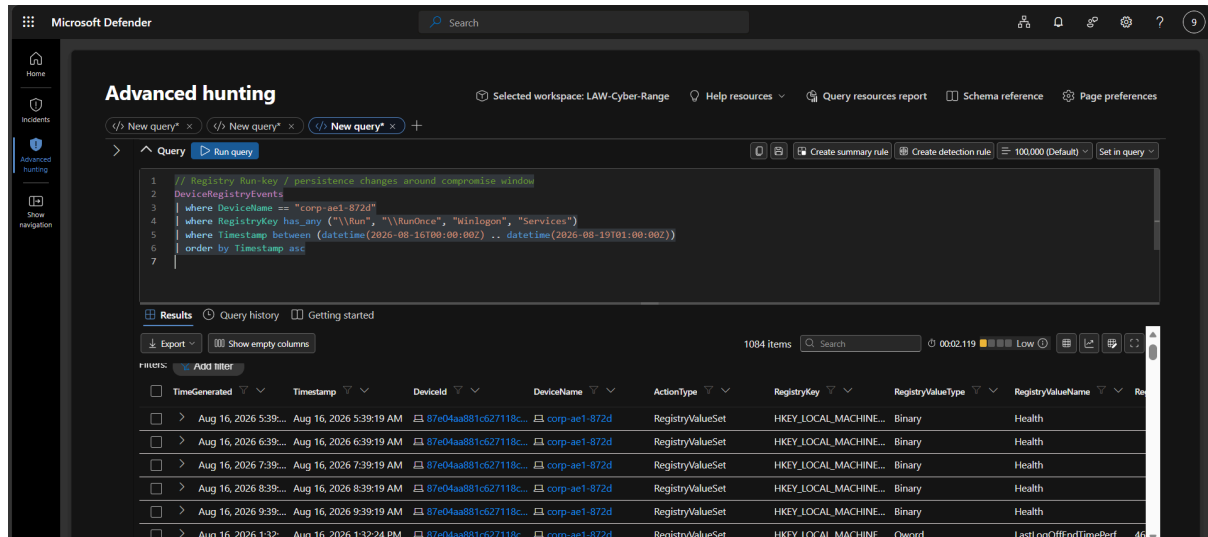
| where DeviceName == "corp-ae1-872d"

| where RegistryKey has_any ("\\Run", "\\RunOnce", "Winlogon", "Services")

| where Timestamp between (datetime(2026-08-16T00:00:00Z) ..

datetime(2026-08-19T01:00:00Z))

| order by Timestamp asc



9. Lessons Learned / Recommendations (prioritized)

1. **[Critical]** Remove MySQL from direct internet exposure; enforce network-layer restriction (security group/firewall) to known management IPs or a VPN/bastion only.
2. **[Critical]** Eliminate blank/weak/default **root** DB credentials; enforce strong unique credentials and disable remote **root** login (use scoped service accounts).
3. **[High]** Restrict/disable direct internet-facing RDP on **corp-ae1-872d**; require MFA + conditional access or move behind a bastion.
4. **[High]** Implement automated, tested, offline/immutable backups for all MySQL databases (**cr_corp_01** in particular) with defined RPO/RTO.
5. **[Medium]** Retain process-level telemetry — **DeviceProcessEvents** — with a longer lookback and export it to the SIEM for every internet-facing host.
6. **[Medium]** Add detection rules for: MySQL **DROP DATABASE** on production schemas, creation of tables/DBs named consistent with known extortion patterns (e.g., **RECOVER_YOUR_DATA**), and RDP logon success following a burst of failures from unrelated ASN/IP ranges.